**Student Name: Nolusindiso Sonjani**

**Student Number: C112617560**

**Course: GRC103**

**Lab: 3**

**Date: 06 November 2026**

**Step 8: Phishing Risk Assessment Table**

| Metric | Result | Calculated Rate | Risk Interpretation | Control Failure |
|---|---|---|---|---|
| Emails Opened | 18/20 | 90% | High susceptibility to engaging with suspicious emails | Security Awareness Training is ineffective |
| Links Clicked | 15/20 | 75% | High risk of users executing malicious actions | Email filtering may be ineffective; users are not verifying links |
| Credentials Submitted | 10/20 | 50% | Critical Risk. High probability of credential compromise | Multi-Factor Authentication (MFA) is required to mitigate this risk |

**Risk Analysis**

**Open Rate Analysis (90%)**

A 90% open rate indicates that employees trust emails that appear to come from legitimate internal sources. Users are not adequately identifying suspicious characteristics in phishing emails.

**Click-Through Analysis (75%)**

A 75% click rate demonstrates a significant weakness in employee security awareness. Most users failed to verify the link destination before clicking.

**Credential Submission Analysis (50%)**

The credential submission rate is the most serious result. Half of the test users entered their credentials into a phishing page, creating a high likelihood of account compromise in a real attack.

## Overall Risk Rating

### Critical Risk

The organization exhibits a high level of exposure to social engineering threats because a successful phishing campaign could lead directly to credential theft, unauthorized access, data breaches, financial losses, compliance violations, and reputational damage.

### Step 9: Executive Summary & Recommendations

**To:** CISO, Head of HR, Executive Management
**From:** GRC Audit Team
**Date:** 06 November 2026
**Subject:** Results of Q3 Controlled Phishing Simulation and Human Risk Assessment

### 1. Executive Summary

A controlled phishing simulation was conducted to assess the organization's resilience to social engineering attacks. The results revealed a critical level of human-related cyber risk. Out of twenty participants, eighteen opened the phishing email, fifteen clicked the malicious link, and ten submitted credentials to the simulated phishing site. These findings indicate a substantial vulnerability to credential theft and unauthorized access attacks.

### 2. Key Findings

| Metric | Result |
|---|---|
| Email Open Rate | 90% |
| Link Click Rate | 75% |
| Credential Submission Rate | 50% |

The 50% credential submission rate represents the most severe finding because it demonstrates that half of the participants would likely compromise their accounts during a real phishing attack.

### 3. Risk Analysis

The phishing simulation indicates weaknesses in current security awareness controls. If exploited by a real attacker, these weaknesses could result in:

- Unauthorized access to corporate systems.
- Theft of confidential information.
- Business disruption.

- Financial losses.
- Regulatory penalties.
- Reputational damage.

The organization is therefore exposed to a significant social engineering risk that requires immediate remediation.

# Recommendations

### 1. Implement Multi-Factor Authentication (MFA)

MFA should be enforced on all critical systems and user accounts. Even if credentials are compromised, MFA provides an additional security layer that significantly reduces unauthorized access.

### 2. Improve Security Awareness Training

Replace annual training sessions with ongoing and interactive phishing awareness programs. Regular simulations and practical exercises will help employees recognize suspicious emails and develop safer online behavior.

### 3. Conduct Quarterly Phishing Simulations

Regular phishing simulations should be integrated into the organization's security program. This will allow management to measure improvements over time and identify departments requiring additional support.

### 4. Strengthen Email Security Controls

Review email filtering policies and implement advanced anti-phishing technologies to detect and block malicious messages before they reach users.

### 5. Update Security Policies

The Acceptable Use Policy should be reviewed and updated to include clear guidance on identifying, reporting, and responding to phishing attempts. Employees should understand their responsibilities in protecting organizational information assets.

## 5. Conclusion

The results of the phishing simulation demonstrate that human error remains one of the organization's most significant cybersecurity risks. By implementing MFA, strengthening user awareness training, conducting regular phishing exercises, and updating security policies, the organization can significantly reduce its exposure to phishing-related threats and improve its overall security posture.